Unit 1. Introduction

1.1 Information System
1.2 Data and Information
1.3 Vulnerability and attacks
1.4 Security Goals
1.5 Security services and mechanisms

Introduction: Information security(CIA)
Information security is the process that describes all measures taken to prevent unauthorized use of electronic data, whether this unauthorized use takes the form of destruction, use, disclosure, modification or disruption. Information security and cryptography are interconnected and share the common services of protecting the confidentiality, integrity and availability of the information ignoring the data form (electronic document, printed document). In the encryption process, information security uses cryptography to shift the information into the cipher form which does not allow it to be used by unauthorized personnel.

Information security, often abbreviated (InfoSec), is a set of security procedures and tools that broadly protect sensitive enterprise information from misuse, unauthorized access, disruption, or destruction. InfoSec encompasses physical and environmental security, access control, and cybersecurity**.**
Importance of information security: Information security protects sensitive information from unauthorized activities, including inspection, modification, recording, and any disruption or destruction. The goal is to ensure the safety and privacy of critical data such as customer account details, financial data or intellectual property**.**

Why We Need Information Security?
Because there are threats.
Threats
A threat is an object, person, or other entity that represents a constant danger to an asset.
Definitions
Computer Security - generic name for the collection of tools designed to
protect data and to the hackers
Network Security - Network security focuses on protecting the network infrastructure and data transmission within a specific network.
Internet Security - Internet security, on the other hand, encompasses the broader protection of systems and data when interacting with the global internet.
Our focus is on Internet Security which consists of measures to prevent, detect, and correct security.

What are Typical Information Security Threats?

Cyber security threats can pose a significant risk to individuals, businesses, and organizations and can result in financial loss, reputational damage, and other serious consequences. The following are the most typical forms of attacks used to commit a security breach.

1. **Malware**: Malware refers to any software designed to harm a computer system, network, or device. Malware can include viruses, Trojans, and worms that can spread through email attachments, malicious websites, or infected software.
2. **Phishing:** Phishing is a type of cyber-attack in which attackers use fraudulent emails or websites to trick individuals into revealing personal information such as credit card details, login credentials, or other sensitive information.
3. **Man-in-the-middle (MitM) attacks:** MitM attacks involve intercepting communication between two parties to steal sensitive information or alter data. These attacks can be particularly dangerous in public Wi-Fi networks, where attackers can easily intercept unencrypted traffic.
4. **Password attacks:** Password attacks involve attempting to crack or guess passwords to gain unauthorized access to a system or network. These attacks can be prevented by implementing strong password policies and multi-factor authentication.
5. **Insider threats:** Insider threats involve employees or other trusted insiders who intentionally or unintentionally cause harm to a system or network. These threats can be prevented by implementing access controls, monitoring user activity, and providing security awareness training.

1.1 Information System:=>

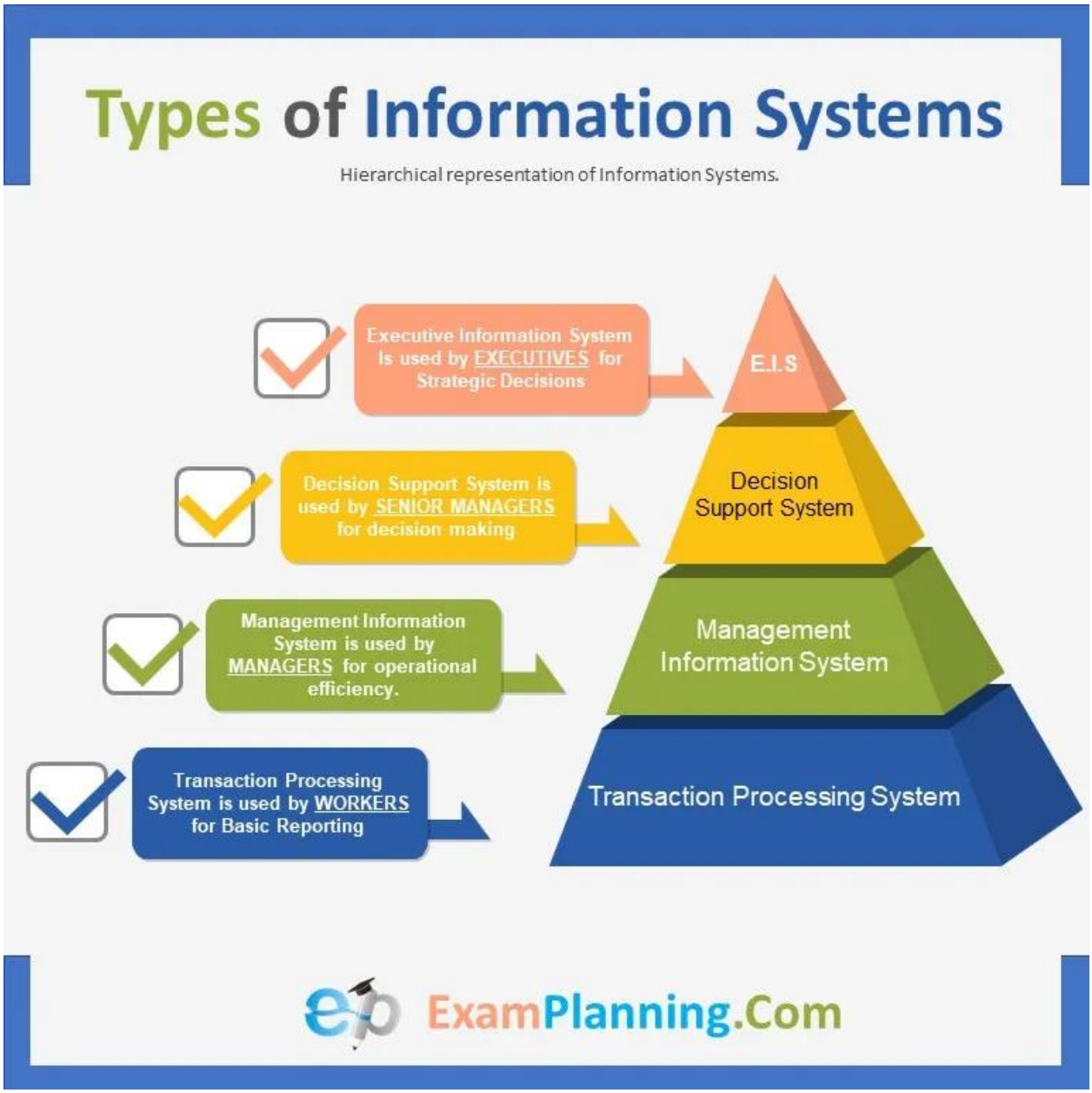
An information system (IS) is a formal, sociotechnical, organizational system designed to collect, process, store, and distribute information. From a sociotechnical perspective, information systems are composed by four components: task, people, structure (or roles), and technology.

=> A typical organization is divided into operational, middle, and upper level.

=> The information requirements for users at each level differ.

=> Towards that end, there are number of information systems that support each level in an organization.

=> Understanding the various levels of an organization is essential to understand the information required by the users who operate at their respective levels



1.2 Data and Information

What Is Data?

Data represents raw elements or unprocessed facts, including numbers and symbols to text and images. When collected and observed without interpretation, these elements remain just data—simple and unorganized. When these pieces are analyzed and contextualized, they transform into something more meaningful.

⇨ Data comes in various forms:

What is information?

- ⇨ You get information when data is processed, organized, interpreted, and structured. The comprehensible output derived from raw data helps inform decisions, strategies, and actions. Information is essentially data made valuable and accessible—an integral component of decision-making.

- ⇨ For instance, if data points include daily temperature readings over a year, information is recognizing the trend of temperatures, understanding seasonal changes, and predicting future weather conditions.

Quantitative data, like an item's weight, volume, or cost, is provided numerically.
Qualitative data is descriptive but non-numerical.

What is the difference between information and data?

- ⇨ Data is an individual unit that contains raw materials which do not carry any specific meaning. Information is a group of data that collectively carries a logical meaning. Data doesn't depend on information. Information depends on data.

- **Data** is raw and unstructured, like individual customer interactions or transaction logs.
- **Information** provides context and insights, like a trend analysis that shows increasing customer satisfaction or sales figures over time.
- **Data** is often abundant and readily available but can be overwhelming without interpretation.
- **Information** is curated and actionable, offering strategic insights to guide business decisions.

1.3 Vulnerability and attacks: =>

Vulnerabilities and attacks in the context of cybersecurity are crucial topics that involve understanding the weaknesses in systems and the methods used to exploit them. Here's an overview of key concepts:

Vulnerabilities

Vulnerabilities are weaknesses or flaws in a system, software, network, or process that can be exploited to compromise security. These can arise from various sources:

1. **Software Bugs:** Errors in code that can be exploited to cause unexpected behavior, crashes, or unauthorized access.
2. **Configuration Issues:** Improper settings that leave systems exposed to attacks, such as default passwords, open ports, or excessive permissions.
3. **Human Factors**: Social engineering exploits human behavior to gain access to systems, often through phishing or manipulation.
4. **Outdated Software**: Using obsolete or unpatched software that lacks security updates makes systems vulnerable to known exploits.
5. **Weak Encryption**: Using outdated or weak encryption algorithms that can be easily broken.

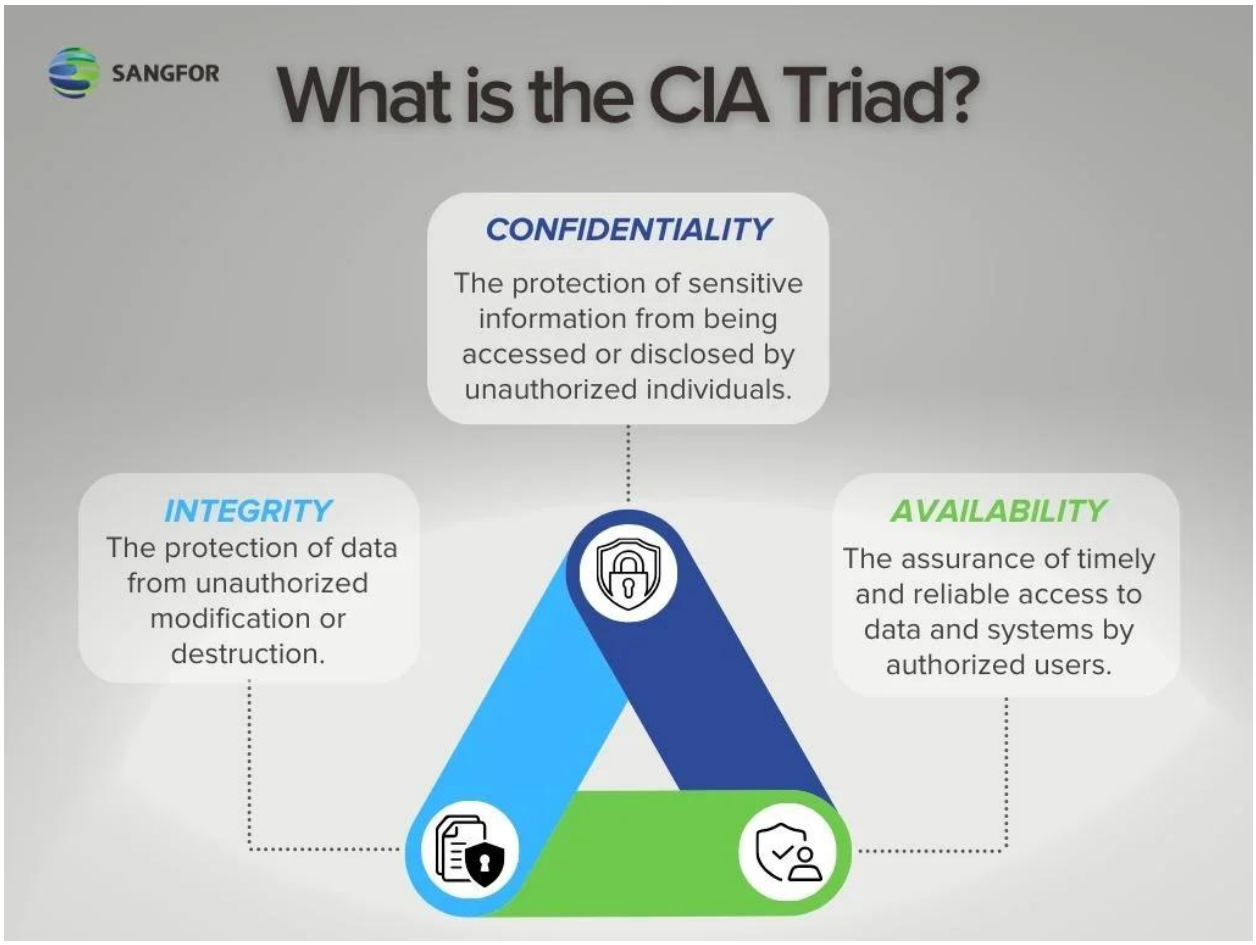
Cyber-attacks:=>

Cyberattacks are malicious attempts to exploit vulnerabilities. Common types of attacks includes: =>

1. **Malware**: Malicious software such as viruses, worms, Trojans , ransomware, and spyware that disrupts, damages, or gains unauthorized access to systems.
2. **Phishing**: Fraudulent attempts to obtain sensitive information by pretending to be a trustworthy entity in electronic communications.
3. **Denial of Service (DoS) and Distributed Denial of Service (DDoS**): Overloading a system or network with traffic to make it unavailable to users.
4. **Man-in-the-Middle (MitM):** Intercepting and altering communication between two parties without their knowledge.
5. **6SQL Injection:** Injecting malicious SQL code into a web application's database query to manipulate or access data.
6. **Cross-Site Scripting (XSS):** Injecting malicious scripts into web pages viewed by other users, enabling the attacker to steal information or perform actions on behalf of the user.
7. **Brute Force Attack:** Attempting to gain access by systematically trying all possible passwords or keys.
8. **Zero-Day Exploit:** Attacks that target vulnerabilities not yet known to the software vendor or public, providing no time for defense.

1.3 Security Goals: =>

Information security is guided by a set of fundamental goals aimed at protecting the confidentiality, integrity, and availability of data. These goals are often referred to as the CIA Triad. Additionally, other security goals such as authenticity and accountability are also important. Here's a detailed explanation of these security goals:



1. Confidentiality

Objective: Ensure that information is accessible only to those authorized to have access.

=>Encryption: Protects data by transforming it into an unreadable format for unauthorized users.

=> Access Controls: Implementing measures such as passwords, biometric verification, and security tokens to restrict access.

=> Data Classification: Categorizing data based on its sensitivity and applying appropriate protection measures.

2. Integrity

Objective: Ensure the accuracy and completeness of information and protect it from being altered by unauthorized users.

- ⇨ Hashing: Using algorithms to generate a unique value for data, which changes if the data is altered.
- ⇨ Checksums and CRCs: Verifying data integrity by checking sums or cyclical redundancy checks.

- ⇨ Digital Signatures: Authenticating the identity of the sender and ensuring the data has not been altered.

3. Availability

Objective: Ensure that information and resources are available to authorized users when needed.

- ⇨ Redundancy: Implementing backup systems and failover mechanisms.
- ⇨ Disaster Recovery Plans: Preparing strategies to recover from unexpected events like natural disasters, cyber-attacks, or system failures.
- ⇨ Regular Maintenance: Performing routine maintenance to prevent system downtime.

4. Authenticity

Objective: Ensure that the data, transactions, communications, and documents are genuine and that the origin of these is verified.

=>Digital Certificates: Using certificates issued by trusted authorities to verify identities.
=>Two-Factor Authentication (2FA): Adding an additional verification step beyond just passwords.
=> Public Key Infrastructure (PKI): Managing digital keys and certificates for secure communication.

5. Accountability

Objective: Ensure that actions and operations can be traced to the entity responsible for them.

- ⇨ Audit Logs: Maintaining logs of system activities to track who accessed or modified data.
- ⇨ Non-Repudiation: Ensuring that a sender cannot deny sending a message and a recipient cannot deny receiving it, typically through the use of digital signatures and timestamps.
- ⇨ Access Control Policies: Defining and enforcing policies to ensure that users have appropriate access rights based on their roles and responsibilities.

Confidentiality, Integrity and Availability (CIA Triad)

The CIA triad consists of three core principles – confidentiality, integrity, and availability (CIA). Together, these principles serve as the foundation that guides information security policies. Here is a brief overview of each principle:

1. **Confidentiality** – information must only be available to authorized parties.
2. **Integrity** – information must remain consistent, trustworthy, and accurate.
3. **Availability** – information must remain accessible to authorized parties, even during failures (with minimal or no disruption).

1.4 Security services and mechanisms: =>

Security mechanism – A mechanism that is designed to detect, prevent or recover from a security attack. Security service – A service that enhances the security of the data processing systems and the information transfers of an organization.

Information security mechanisms are processes, techniques, or tools designed to detect, prevent, or recover from security attacks, ensuring Confidentiality, Integrity, and Availability (CIA). Core mechanisms include cryptography, access control, and firewalls, which form a layered defense to protect data against unauthorized access and modification.

Types of Security Mechanism

- Encipherment (Encryption)**:** Hides information by converting plaintext into ciphertext using algorithms and keys (e.g., AES, DES). Provides confidentiality.
- Access Control**:** Restricts access to resources based on authorization policies (e.g., passwords, Biometrics, PINs, Firewalls).
- Data Integrity**:** Ensures data is not altered in transit or storage using techniques like hashing or checksums.
- Digital Signatures**:** Appends encrypted data to a message to prove the sender's identity (authenticity) and ensure the message hasn't changed.
- Authentication Exchange**:** Verifies the identity of entities communicating (e.g., handshaking protocols).
- Traffic Padding**:** Inserts dummy data into the network to hide traffic patterns from attackers.
- Routing Control**:** Selects secure physical paths for sensitive data to prevent interception.
- Notarization**:** Uses a trusted third party to validate the properties of a data exchange.

Classification of Mechanisms

- Specific Security Mechanisms**:** Implemented in specific protocol layers to provide security services (e.g., Encryption, Digital Signatures).
- Pervasive Security Mechanisms**:** General, system-wide controls not tied to a specific layer (e.g., Trusted functionality, Event detection, Security audits).

Security services in information security: =>

Security services in information security are specialized methods and tools—often defined by standards like X.800—designed to protect systems and data transfers. They enforce security policies, provide confidentiality, integrity, availability, and authenticity, and are implemented through mechanisms like encryption, firewalls, and access controls.

Core Security Services (The 5 Pillars)

These services directly address the CIA Triad (Confidentiality, Integrity, Availability) and related needs:

- **Confidentiality (Data Secrecy):** Ensures sensitive info is only accessed by authorized users.
  - *Mechanism:* Encryption (scrambling data) and access control.
- **Integrity (Data Accuracy):** Ensures data is not altered or tampered with during storage or transmission.
  - *Mechanism:* Hashing, checksums, and digital signatures.
- **Availability (Data Accessibility):** Ensures authorized users have reliable, timely access to data and resources.
  - *Mechanism:* Redundancy (backups), load balancing, and DDoS protection.
- **Authentication (Identity Verification):** Confirms that a user or system is who they claim to be.
  - *Mechanism:* Passwords, biometrics, and Multi-Factor Authentication (MFA).
- **Authorization (Access Management):** Determines what an authenticated user is permitted to do.
  - *Mechanism:* Role-Based Access Control (RBAC) and Access Control Lists (ACLs).
- **Non-Repudiation (Accountability):** Ensures a party cannot deny their actions (e.g., sending a message or making a purchase).
  - *Mechanism:* Digital signatures and audit logs.

Security Services vs. Mechanisms (Key Distinction)

- **Service (Goal):** What you want to achieve (e.g., "Keep data private").
- **Mechanism (Tool):** How you achieve it (e.g., "Use AES encryption").